

# Ameaças Sintéticas: A Eficácia de LLMs na Evasão de Filtros de *Phishing*

Miguel Grilo<sup>1\*</sup>, Tiago Palaio<sup>2\*</sup> and João Santos<sup>2\*</sup>

<sup>1\*</sup>Inteligência Artificial e Ciências de Dados, Universidade de Évora, Évora, Portugal.

<sup>2\*</sup>Engenharia Informática, Universidade de Évora, Évora, Portugal.

\*Corresponding author(s). E-mail(s): {158387, 162276, 162472}@alunos.uevora.pt;

## Abstract

O rápido avanço da Inteligência Artificial (IA) generativa e dos *Large Language Models* (LLMs) transformou irreversivelmente o panorama da cibersegurança, dotando os cibercriminosos de ferramentas capazes de automatizar e refinar campanhas de engenharia social. Este estudo investiga a eficácia destas tecnologias emergentes na conceção de ataques de *phishing* e na consequente evasão a filtros de *spam* comerciais. Através de uma experiência empírica controlada, avaliou-se a taxa de entrega de um *corpus* diversificado de vinte *e-mails* simulados — divididos entre matrizes tradicionais (redigidas por humanos) e variantes otimizadas por múltiplos modelos de IA (Gemini, Qwen, Claude, ChatGPT) — remetidos a partir de domínios legítimos para um ambiente Microsoft Outlook. Os resultados demonstram de forma inequívoca a superioridade tática das abordagens sintéticas: enquanto as defesas algorítmicas convencionais conseguiram interceptar e reter no lixo eletrónico uma tentativa rudimentar de conceção humana, a totalidade dos dezasseis *e-mails* gerados por IA (100%) penetrou a caixa de entrada principal sem acionar qualquer alerta. Estas observações corroboram a literatura recente, evidenciando que a IA generativa neutraliza as heurísticas tradicionais de deteção através de uma emulação irrepreensível da semântica, tom e formatação corporativa. O estudo conclui que os atuais paradigmas de defesa e de consciencialização dos utilizadores encontram-se obsoletos, exigindo uma transição urgente para frameworks de segurança híbridas que integrem análise comportamental e mecanismos de triagem impulsionados pela própria IA.

**Keywords:** Phishing, Cibersegurança, LLM, Engenharia Social, Inteligência Artificial.

# 1 Introdução

A introdução em massa de ferramentas de inteligência artificial no nosso dia a dia - seja no trabalho, na escola ou na vida pessoal - trouxe consigo mudanças significativas e fundamentais no modo como interagimos com informação na rede. A sua acessibilidade e imensa capacidade de computação permitem a geração de conteúdo - seja ele benigno ou malicioso - com uma facilidade até antes não vista.

Utilizadores maliciosos de LLMs conseguem utilizar estas capacidades para realizar ataques em escala com maior facilidade e menores custos do que nunca [1] [2], sendo o *phishing* em particular uma das estratégias de maior sucesso. A utilização de LLMs, para além de reduzir o tempo e dificuldade da realização dos ataques, permite ainda consolidar informação e escrever mensagens ou *E-mails* suficientemente convincentes e personalizados a cada alvo [3], sejam estes indivíduos ou organizações.

## 2 Estado da arte

### 2.1 *Large Language Models* (LLMs)

Importa, antes de mais, definir alguns conceitos.

Um *LLM* - *Large Language Model* - é um sistema avançado que emprega várias técnicas de processamento de linguagens e extensos conjuntos de dados e parâmetros à sua disposição, com capacidades cada vez mais avançadas de compreensão, geração e tradução de texto, assim como uma crescente capacidade de identificar contextos, seguir ordens complexas e imitar estilos e vícios de escrita *humanos*. [2] [3] [4]. A sua capacidade cresce mais ainda quando se treinam modelos especializados para tarefas específicas, incluindo modelos maliciosos como o WormGPT [5] que removem as salvaguardas tipicamente encontradas em modelos comerciais. Modelos *open-source*, embora frequentemente munidos destas salvaguardas, são modificáveis de modo a remover ou contorná-las.

No contexto da cibersegurança, a utilização de *LLMs* tanto pode ser positiva como negativa. Os mesmos métodos de treino para a deteção de conteúdo malicioso servem de igual modo para a sua produção. Está então criada uma “corrida” de parte a parte, onde ambos os lados utilizam as mesmas ferramentas de modos opostos.

### 2.2 Engenharia Social e *Phishing*

*Engenharia Social* é a utilização do “elo fraco” de um sistema de informação - o próprio utilizador - como principal vetor de ataque, utilizando a psicologia humana e não eventuais falhas técnicas do sistema para fins maliciosos [6] [7]. Assenta-se principalmente na utilização de técnicas de persuasão e construção de confiança com os alvos [7] de forma a realizar um ataque ou obter informação indevida. Tipicamente, são necessários alguns componentes para a realização de um ataque desta tipologia [7]:

- O engenheiro social - o atacante;
- O alvo;
- Um meio de comunicação;
- Um objetivo;

- A aplicação de técnicas coercivas

Dentro destes ataques, os de *phishing* são os mais comuns e, de grosso modo, os mais eficazes. Entregues quer por *e-mail*, mensagem de texto, anúncios (particularmente em redes sociais) e até *websites* completos (mas inteiramente fraudulentos) um ataque de *phishing* devidamente estruturado emprega técnicas fundamentais da engenharia social - linguagem e pedidos urgentes ou tentadores, como a utilização de conteúdo não verificável por humanos como códigos QR (*quishing*) ou outras formas de conteúdo dinâmico e de difícil análise [1] de maneira a conseguir obter diretamente informação da vítima ou criar um ponto de acesso para futuros ataques de outra natureza, como a instalação de *malware* [3] [8].

Estes ataques são extremamente comuns, afetando mais de 80% das empresas e instituições [3], tendo um impacto económico massivo - na ordem dos milhares de milhões de dólares/euros em prejuízo - com centenas de milhares de ataques com sucesso em cada ano [8] e a aumentar. Estatísticas de 2024 indicavam um aumento de 94% em ataques de *phishing* em comparação com apenas 4 anos antes.

## 2.3 Impacto da IA na Evolução do *Phishing*

No contexto de ataques de *phishing*, o *spear-phishing* é uma forma mais sofisticada de ataque, trocando o envio em massa de mensagens fraudulentas genéricas por conteúdo altamente personalizado, direcionado a um indivíduo ou organização [3] [8] em particular. Esta acrescida sofisticação levanta problemas quanto à eficácia dos já desenvolvidos filtros e ferramentas de combate a *e-mails* fraudulentos [3], construídos em grande parte com a aprendizagem em massa de *padrões* típicos a *e-mails* fraudulentos escritos por humanos: erros ortográficos, má estrutura, informações e linguagem imprecisas e moldes contextuais partilhados, tais como ofertas de produtos e serviços ou falsos alertas de segurança.

Naturalmente, o nível de cuidado necessário para corrigir as falhas típicas dos *e-mails* maliciosos é dispendioso - em particular a nível de tempo - e é aí que os LLM entram. A automatização de pesquisa e agregação de informação permite uma redução significativa na criação de “perfis” de ataque relativamente precisos e, de acordo com um relatório partilhado pela IBM em 2023, esta redução de custo é extremamente significativa: o tempo de criação de um *e-mail* de *phishing* é reduzido de 16 horas em equipa para 5 minutos [9] com escassos *prompts* num modelo comercial e, de acordo com Heiding et al. [2] o custo financeiro de campanhas de *spear-phishing* pode diminuir para níveis similares aos de envio de *e-mails* genéricos em massa.

## 2.4 Divergências na Literatura e Hipóteses de Estudo

É transversal a toda a bibliografia analisada que a inteligência artificial é uma ferramenta poderosa tanto para o combate como para a realização de ataques informáticos. No entanto, são também visíveis pontos de divergência entre as diversas análises ao tópico, particularmente em questões relativas à verdadeira eficácia (eg: *melhores que humanos?*) dos modelos testados, quer em situações de ataque ou defesa.

Uma outra linha de pensamento por vezes contraditória tem que ver com um possível paradoxo de sofisticação: à medida que as estratégias de ataque se tornam mais complexas, torna-se mais fácil detetar as *fraudes*.

Zhou [10] afirma num estudo de 2025 que “de forma contra-intuitiva”, os ataques “meticulosamente desenhados” são “mais facilmente identificados por sistemas AI” em oposição a ataques “genéricos, menos estruturados”. As afirmações baseiam-se na menor taxa de falsos-negativos apresentada durante os testes.

Em contraponto, Afane et al. [11] avançam que a precisão de detetores de *spam* e *phishing* decrescem quando são usados contra “tentativas mais súbtis de ataque, geradas por LLMs”, justificando as conclusões com o facto dos LLMs conseguirem re-escrever *e-mails* conhecidos de forma neutra e natural, que dificulta a classificação por parte dos detetores.

Com este conflito em conta, foi delineada uma experiência para validação de dados, de forma a perceber qual o grau *efetivo* de interceção de possíveis tentativas de ataque e qual o impacto do uso de inteligência artificial para estes fins.

Será possível, em 2026, que a simples utilização de prompts de “limpeza” em *phishing* conhecido seja suficiente para contornar filtros?

Serão *e-mails* inteiramente criados por AI capazes do mesmo?

E serão estas tipologias de ataque mais eficazes a ultrapassar tais filtros do que *e-mails* escritos por humanos?

### 3 Metodologia

A presente investigação adota uma abordagem empírica estruturada para avaliar a resiliência dos mecanismos de filtragem de correio eletrónico contemporâneos face a ameaças cibernéticas de nova geração. Para testar as hipóteses levantadas na literatura — nomeadamente a de que as IAs generativas reduzem a dependência das *red flags* operacionais —, desenvolveu-se uma experiência prática em condições reais de funcionamento. O objetivo primário consistiu em observar e avaliar a capacidade de evasão destas ameaças sintéticas face aos mecanismos de filtragem do Microsoft Outlook, quando expostos a uma amostra mista de tentativas de *phishing*.

#### 3.1 Desenho da Amostra

O *corpus* experimental foi expandido para garantir maior robustez analítica, sendo constituído por vinte *e-mails* simulados de *phishing*, rigorosamente divididos em duas categorias tipológicas:

- **E-mails Tradicionais (Conceção Humana):** Quatro *e-mails* (Mail\_1, Mail\_5, Mail\_7 e Mail\_8) que replicam táticas e estruturas clássicas de ataques, recuperados e adaptados a partir de bases de dados publicamente acessíveis (Champa et al. [12]). Estas comunicações mantiveram deliberadamente os marcadores heurísticos habituais (*red flags*), tais como formulações genéricas e falhas estruturais.
- **E-mails Gerados por IA:** Dezasseis *e-mails* inteiramente concebidos através de *prompts* submetidos a quatro LLMs distintos, garantindo a diversidade dos dados: **Gemini** (Mails 2, 3, 4 e 6), **Qwen** (Mails 9, 10, 11 e 12), **Claude** (Mails 13, 14,

15 e 16) e **ChatGPT** (Mails 17, 18, 19 e 20). Tirando partido das capacidades semânticas avançadas destes modelos, as IAs foram instruídas para redigir iscos de engenharia social assentes num tom neutro, gramática impecável e num elevado grau de formalidade institucional.

### 3.2 Infraestrutura e Procedimento de Teste

Para isolar a eficácia da componente semântica gerada por IA e mitigar o risco de os *e-mails* serem bloqueados puramente com base na reputação negativa de domínios recém-criados ou sinalizados, os envios foram efetuados a partir de contas de correio legítimas e consolidadas no ecossistema Google. Utilizaram-se contas **@gmail.com** de uso pessoal e contas académicas associadas a instituições de ensino superior.

O alvo designado para a receção dos vetores de ataque foi uma conta criada especificamente para este propósito na plataforma Microsoft Outlook. Esta escolha permitiu avaliar a resposta fidedigna do filtro algorítmico *Exchange Online Protection* (EOP) a operar nas suas definições de segurança *standard* para o utilizador final. A variável dependente analisada consistiu na classificação e local de entrega da mensagem: “Caixa de Entrada” (representando uma evasão bem-sucedida) ou “Lixo Eletrónico (Junk)” (representando uma interceção eficaz pelo filtro).

## 4 Resultados e Discussão

A submissão do *corpus* documental ao filtro de *spam* do Microsoft Outlook revelou disparidades acentuadas entre a eficácia das abordagens de engenharia social tradicionais e aquelas mediadas por Inteligência Artificial. A Tabela 1 sumariza o destino final de cada mensagem testada, classificando o respetivo *status* de evasão algorítmica.

De forma global, a experiência registou uma taxa de evasão algorítmica de 95%, correspondente à intrusão bem-sucedida de dezanove das vinte ameaças remetidas. Todavia, a avaliação rigorosa desta métrica desvenda um padrão extremamente crítico: os dezasseis vetores de ataque gerados por IA registaram uma taxa de penetração absoluta de 100% na caixa de entrada principal. Por contraste, a única intervenção eficaz do sistema de segurança — que culminou na retenção em quarentena do **Mail\_8** — incidiu sobre um documento de conceção exclusivamente humana.

### Análise Qualitativa dos E-mails

Uma análise qualitativa das diferenças estruturais e semânticas entre as amostras clarifica o porquê destas disparidades. Os *e-mails* de conceção humana, mesmo aqueles que evadiram com sucesso os filtros, frequentemente socorriam-se de apelos emocionais abruptos e possuíam inconsistências típicas de comunicação em massa. Em contrapartida, os textos gerados por IA demonstraram uma formatação camuflada de normalidade rotineira. Entre as diferentes matrizes sintéticas, observaram-se nuances: o **Claude** distinguiu-se pela produção de um discurso mais fluido, natural e empático; o **ChatGPT** apresentou redações com uma cadência corporativa impecável e altamente padronizada; o **Gemini** adotou uma postura de neutralidade assertiva, ideal para mimetizar notificações de *IT*; e o **Qwen** gerou instâncias marcadamente mais

**Table 1** Resultados da Evasão de Filtros por e-mail Testado.

| Identificador | Tipologia/Origem        | Destino Final          | Status de Evasão |
|---------------|-------------------------|------------------------|------------------|
| Mail_1        | Humano (Tradicional)    | Caixa de Entrada       | Sucesso          |
| Mail_2        | IA Generativa (Gemini)  | Caixa de Entrada       | Sucesso          |
| Mail_3        | IA Generativa (Gemini)  | Caixa de Entrada       | Sucesso          |
| Mail_4        | IA Generativa (Gemini)  | Caixa de Entrada       | Sucesso          |
| Mail_5        | Humano (Tradicional)    | Caixa de Entrada       | Sucesso          |
| Mail_6        | IA Generativa (Gemini)  | Caixa de Entrada       | Sucesso          |
| Mail_7        | Humano (Tradicional)    | Caixa de Entrada       | Sucesso          |
| Mail_8        | Humano (Tradicional)    | Lixo Eletrônico (Junk) | Bloqueado        |
| Mail_9        | IA Generativa (Qwen)    | Caixa de Entrada       | Sucesso          |
| Mail_10       | IA Generativa (Qwen)    | Caixa de Entrada       | Sucesso          |
| Mail_11       | IA Generativa (Qwen)    | Caixa de Entrada       | Sucesso          |
| Mail_12       | IA Generativa (Qwen)    | Caixa de Entrada       | Sucesso          |
| Mail_13       | IA Generativa (Claude)  | Caixa de Entrada       | Sucesso          |
| Mail_14       | IA Generativa (Claude)  | Caixa de Entrada       | Sucesso          |
| Mail_15       | IA Generativa (Claude)  | Caixa de Entrada       | Sucesso          |
| Mail_16       | IA Generativa (Claude)  | Caixa de Entrada       | Sucesso          |
| Mail_17       | IA Generativa (ChatGPT) | Caixa de Entrada       | Sucesso          |
| Mail_18       | IA Generativa (ChatGPT) | Caixa de Entrada       | Sucesso          |
| Mail_19       | IA Generativa (ChatGPT) | Caixa de Entrada       | Sucesso          |
| Mail_20       | IA Generativa (ChatGPT) | Caixa de Entrada       | Sucesso          |

diretas e concisas. Transversal a todos os modelos foi a completa erradicação de gralhas ortográficas e a sofisticação da sintaxe, mitigando os tradicionais indícios probabilísticos de fraude.

A eficácia imaculada dos modelos sintéticos valida de forma cabal as observações empíricas de autores como Kumara et al. [6] e Afane et al. [11], que alertam para a capacidade inerente aos LLMs de contornar defesas tradicionais ao fundir o engano na cadência natural da comunicação corporativa (ver Figuras 2 e 3 para exemplos gerados pelo Gemini).

Por sua vez, o aprisionamento do Mail\_8 no diretório de lixo eletrônico (ver Figura 4) atesta que as heurísticas de detecção convencionais permanecem funcionais quando confrontadas com padrões de ataque rudimentares ou não refinados. A presença de desvios gramaticais evidentes e de uma formulação pouco sofisticada acionou, com sucesso, os algoritmos de triagem da plataforma Microsoft. Contudo, importa salientar que três dos quatro *e-mails* de raiz humana (Mails 1, 5 e 7) não foram interceitados. Tal ocorrência indicia que a sólida reputação do domínio emissor — neste caso, contas acadêmicas e pessoais validadas pelo ecossistema Google — atua como um fator de mitigação de risco passivo para o algoritmo de triagem, acabando por tolerar pequenas falhas estruturais que, noutro contexto ou domínio, originariam o bloqueio imediato da mensagem.

Esta evidência suporta fortemente a tese de que a cibersegurança moderna enfrenta um limiar de complexidade assimétrico. A convergência entre infraestruturas de envio com elevada reputação e o refinamento semântico exímio providenciado pela IA

## Taxa de Evasão: Conceção Humana vs. IA

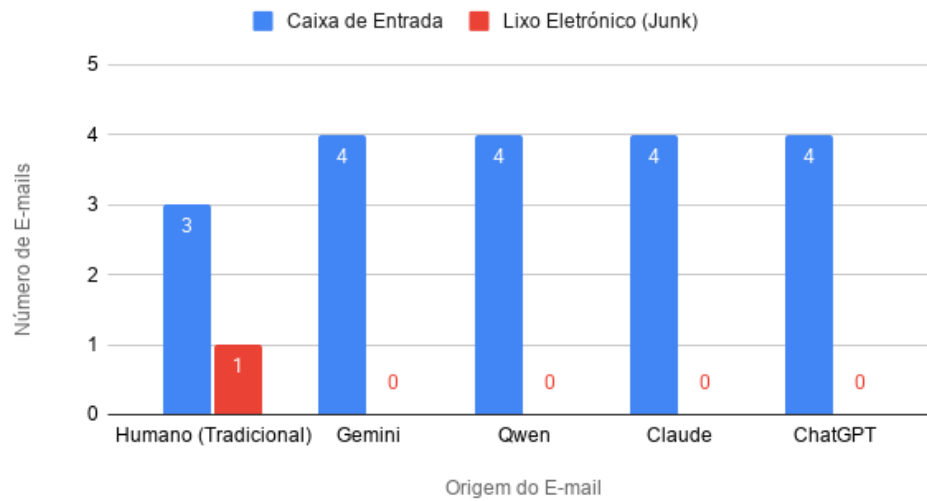


Fig. 1 Taxa de Evasão: Conceção Humana vs. IA.

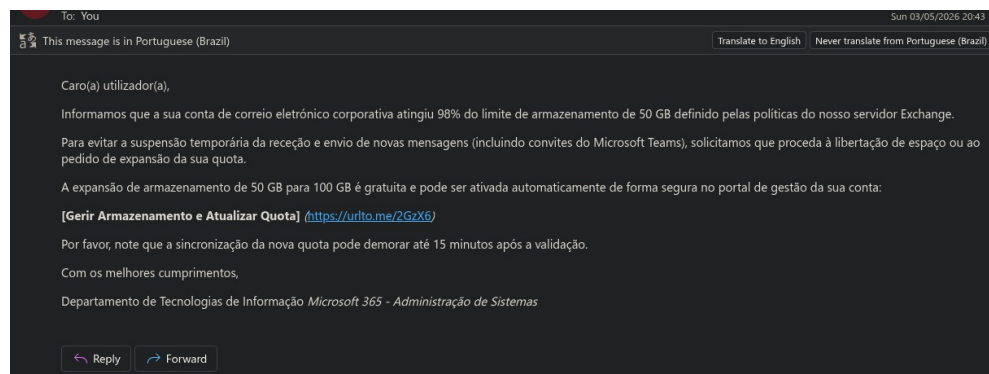
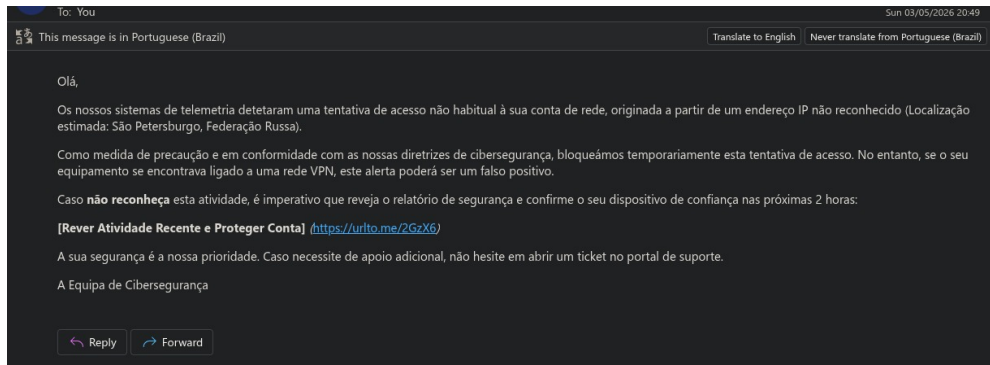
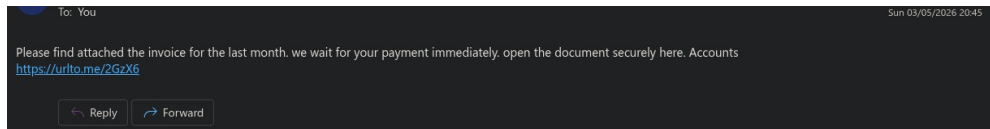


Fig. 2 E-mail gerado por IA (Mail\_3) entregue na Caixa de Entrada.

generativa confere aos cibercriminosos uma via de penetração praticamente desimpedida. Em suma, os filtros superficiais que assentam os seus modelos de confiança primariamente em assinaturas estáticas ou em erros redacionais demonstram-se manifestamente insuficientes face a ameaças desprovidas das clássicas vulnerabilidades humanas.



**Fig. 3** E-mail gerado por IA (Mail\_6) entregue na Caixa de Entrada.



**Fig. 4** E-mail humano (Mail\_8) retido no lixo eletrônico.

## 5 Conclusão

A presente investigação propôs-se a analisar criticamente o impacto transformacional da Inteligência Artificial (IA) generativa e dos *Large Language Models* (LLMs) na execução e eficácia dos ataques de *phishing*. Os dados empíricos recolhidos, suportados agora por uma amostra diversificada, alinham-se e corroboram as perspetivas de diversos autores na área. Em concordância com Schmitt e Flechais [3] e Afane et al. [11], a integração destas tecnologias confere aos agentes maliciosos uma assimetria tática substancial. A automatização da engenharia social democratizou o acesso a vetores de ataque altamente persuasivos.

Através do *corpus* analítico testado ( $n = 20$ ), observou-se que as abordagens humanas tradicionais, reféns de falhas heurísticas, mantêm alguma suscetibilidade aos mecanismos de triagem convencionais. Em contrapartida, todas as variantes sintéticas — sem distinção entre os modelos Gemini, Qwen, Claude ou ChatGPT — alcançaram uma taxa de evasão absoluta (100%). A conjugação de iscos linguisticamente irrepreensíveis com domínios emissores de elevada reputação provou ser suficiente para contornar os filtros baseados em assinaturas.

Embora se tenha expandido a diversidade de modelos de IA, persistem limitações metodológicas. A utilização exclusiva da plataforma Microsoft Outlook restringe a extrapolação para outros clientes corporativos (e.g., Google Workspace). Além disso, o estudo focou-se em texto e hiperligações inofensivas, omitindo anexos maliciosos ofuscados.

## Implicações Práticas e Orientações

Perante estes resultados, torna-se evidente que os procedimentos operacionais padrão necessitam de revisão. Para os **utilizadores finais**, a ausência de erros ortográficos ou gramaticais não pode continuar a ser um indicador de legitimidade. É urgente promover um ceticismo saudável em relação a comunicações imprevistas, incentivando a verificação de identidade *out-of-band* (ex: contactar a entidade emissora via chamada telefónica antes de clicar em links ou descarregar anexos).

Para **profissionais e equipas de cibersegurança**, os dados indicam a obsolescência das defesas puramente reativas. Recomenda-se vivamente:

- A integração de soluções de segurança de e-mail (SEG - *Secure E-mail Gateways*) que elas próprias utilizem algoritmos de IA e *Machine Learning* focados na análise comportamental e na identificação de anomalias semânticas e contextuais.
- A implementação e monitorização estrita de protocolos rigorosos de autenticação (DMARC, SPF, DKIM) para prevenir o *spoofing* de domínios.
- A reformulação de campanhas de *awareness* corporativas para focar no reconhecimento de táticas de manipulação psicológica e urgência infundada presentes no *spear-phishing* gerado por IA, em vez de depender apenas do reconhecimento visual de formatação deficiente.

Apenas através da adoção de *frameworks* dinâmicas e proativas será viável resguardar a integridade das comunicações e mitigar o engano sintético na era contemporânea do cibercrime.

## References

- [1] Shepherd, N.: The role of generative ai in social engineering and phishing: Implications for security education (2024) <https://doi.org/10.5281/zenodo.18257785>
- [2] Heiding, F., Schneier, B., Vishwanath, A., Bernstein, J., Park, P.: Devising and detecting phishing emails using large language models. *IEEE Access* **PP**, 1–1 (2024) <https://doi.org/10.1109/ACCESS.2024.3375882>
- [3] Schmitt, M., Flechais, I.: Digital deception: Generative artificial intelligence in social engineering and phishing. *SSRN Electronic Journal* (2023) <https://doi.org/10.2139/ssrn.4602790>
- [4] Jaffal, N., Alkhanafseh, M., Mohaisen, D.: Large language models in cybersecurity: A survey of applications, vulnerabilities, and defense techniques. *AI* **6**, 216 (2025) <https://doi.org/10.3390/ai6090216>
- [5] Firdhous, M., Elbreiki, W., Abdullahi, I., Sudantha, B., Budiarto, R.: Wormgpt: A large language model chatbot for criminals, pp. 1–6 (2023). <https://doi.org/10.1109/ACIT58888.2023.10453752>
- [6] Kumarage, T., Johnson, C., Adams, J., Ai, L., Kirchner, M., Hoogs, A., Garland, J., Hirschberg, J., Basharat, A., Liu, H.: Personalized attacks of social engineering in multi-turn conversations – llm agents for simulation and detection (2025) <https://doi.org/10.48550/arXiv.2503.15552>
- [7] Mouton, F., Leenen, L., Malan, M., Venter, H.s.: Towards an ontological model defining the social engineering domain, vol. 431 (2014). [https://doi.org/10.1007/978-3-662-44208-1\\_22](https://doi.org/10.1007/978-3-662-44208-1_22)
- [8] Han, W., Zhu, J., Zhang, C., Zhang, Z., Mei, Y., Wang, L.: Phish-master: Leveraging large language models for advanced phishing email generation and detection. *Applied Sciences* **15**(22) (2025) <https://doi.org/10.3390/app152212203>
- [9] Carruthers, S.: Ai vs. human deceit: Unravelling the new age of phishing tactics. Technical report, IBM X-Force (2023). Acedido em: 05/05/2026. <https://www.ibm.com/think/x-force/ai-vs-human-deceit-unravelling-new-age-phishing-tactics>
- [10] Zhou, J.: Can mllms detect phishing? a comprehensive security benchmark suite focusing on dynamic threats and multimodal evaluation in academic environments (2025) <https://doi.org/10.48550/arXiv.2511.15165>
- [11] Afane, M., Wei, W., Mao, Y., Farooq, J., Chen, J.: Next-generation phishing: How llm agents empower cyber attackers, pp. 2558–2567 (2024). <https://doi.org/10.1109/BigData62323.2024.10825018>

- [12] Champa, A., Rabbi, M.F., Zibran, M.: Curated datasets and feature analysis for phishing email detection with machine learning, pp. 1–7 (2024). <https://doi.org/10.1109/ICMI60790.2024.10585821>